

# Chapter 11

## Vulnerability Scoring

# CVSS Overview

Common Vulnerability  
Scoring System

Measures severity  
of vulnerabilities

Derives for CVE data

Based on multiple factors

## CVSS Score Range

Scores range from 0-10

Higher score means a  
higher severity

Represents impact if exploited

Used for prioritization

## CVSS Metrics Evolution

Version 3.1 used 8 metrics

Version 4 uses 12 metrics

Increased precision over time

Expands evaluation factors

## Comparing CVSS Scores

Compare severity  
across vulnerabilities

Identify higher risk issues

Focus on key differences

Supports prioritization decisions

# Attack Surface Metrics

## Attack Vector

- Requires privilege level

## Attack Complexity

- High, low, or none

## Attack Requirements

- Present or not on the system

## Define access needed

- High level of privileges, low, or none
- Active or passive user

## Impact and Exploit Maturity

CIA impact on systems

Effects on connected systems

Exploit maturity level

Proof of concept or active use

## EPSS Overview

Exploit Prediction Scoring System

Measures likelihood of exploitation

Complements CVSS severity

Supports risk prioritization

## CVSS vs EPSS

CVSS measures severity

EPSS measures likelihood

Combined for better analysis

Supports informed decisions

# Chapter 11

## Vulnerability Management

# Attack Surface Reduction

Every entry, interaction, or data-extraction point an attacker can reach

- Shrink it to limit threat-actor avenues
- Fewer points = fewer channels to monitor

# Version and Configuration Tracking

Version numbers track systems and configs as they change

- Trace issues to a version; identify all affected systems fast

# Patching and Software Updates

Software ships with hidden flaws that surface over time

- Patch before threat actors exploit the weakness
- Use automated updates and central patch management

# Security Exceptions

Temporary deviations from policy for business or technical needs

- E.g., adding a vulnerable system to validate scanner accuracy
- Must be controlled, documented, and time-limited

## Maintaining Security Posture

Combine secure policies, vigilant users, and strong tools

- Every hardening practice covered here is essential